

Cybersecurity Daily Newsletter

Vol. 001 | 2026-05-18 07:00 WIB

Top 5 Highlights

- New Windows 'MiniPlasma' zero-day exploit gives SYSTEM access, PoC released
- [+24h Old] PoC code published for critical NGINX vulnerability (CVE-2026-42945)
- Grafana Labs security breach: attackers accessed GitHub token and downloaded private codebase
- [+24h Old] Shai-Hulud worm steals npm, GitHub, AWS, and Kubernetes secrets from developers
- [+24h Old] Google Project Zero discloses zero-click exploit chain for Pixel 10 devices

Threat Intelligence (10)

01. Tycoon2FA phishing kit adds OAuth device-code flow to hijack Microsoft 365 accounts

Researchers observed Tycoon2FA campaigns that lure targets through layered redirects and then trick them into completing Microsoft's legitimate device-login flow. Victims unknowingly authorize an attacker-controlled device, granting the actor access tokens to M365 services.

Why it matters: Device-code phishing can bypass typical credential protections and quickly lead to mailbox access, session/token theft, and downstream SaaS compromise.

Recommendation: Disable device-code flow where not needed, tighten OAuth consent and app approval, and monitor Entra logs for deviceCode auth events and anomalous user agents.

Sources: <https://www.bleepingcomputer.com/news/security/tycoon2fa-hijacks-microsoft-365-accounts-via-device-code-phishing/> | <https://www.esentire.com/blog/tycoon-2fa-operators-adopt-oauth-device-code-phishing> | <https://www.proofpoint.com/us/blog/threat-insight/device-code-phishing-evolution-identity-takeover>

02. [+24h Old] Russian-linked Secret Blizzard evolves Kazuar backdoor into a modular peer-to-peer botnet

Microsoft detailed how newer Kazuar variants use kernel/bridge/worker modules and elect a single 'leader' host to reduce external C2 traffic. The design improves stealth by keeping most infected systems in silent mode while still enabling collection and exfiltration.

Why it matters: P2P designs reduce detection surface and support long-dwell espionage operations, increasing the risk of sustained data theft from targeted environments.

Recommendation: Prioritize behavior-based detections, hunt for unusual IPC (named pipes/mailslots) patterns, and audit outbound proxy traffic tied to rare WebSockets/EWS patterns.

Sources: <https://www.bleepingcomputer.com/news/security/russian-hackers-turn-kazuar-backdoor-into-modular-p2p-botnet/> | <https://www.microsoft.com/en-us/security/blog/2026/05/14/kazuar-anatomy-of-a-nation-state-botnet/>

03. [+24h Old] KongTuke initial access broker shifts to Microsoft Teams helpdesk lures delivering ModeloRAT

ReliaQuest reports KongTuke operators using external Microsoft Teams chats to impersonate IT/helpdesk staff and convince employees to run a PowerShell command. The chain downloads a ZIP from Dropbox and launches a Python-based RAT with expanded persistence and multi-channel access.

Why it matters: Fast social engineering via collaboration tools can yield initial access in minutes and be resold to ransomware operators for rapid lateral movement and extortion.

Recommendation: Restrict external Teams federation (allowlists), block suspicious tenant outreach, and hunt for unusual PowerShell + Dropbox download patterns and new scheduled tasks.

Sources: <https://www.bleepingcomputer.com/news/security/kongtuke-hackers-now-use-microsoft-teams-for-corporate-breaches/> | <https://reliarequest.com/blog/threat-spotlight-help-desk-lures-drop-kongtukes-evolved-modelorot>

04. [+24h Old] OpenAI confirms employee devices impacted by TanStack 'Mini Shai-Hulud' supply-chain campaign

OpenAI disclosed that two employees' devices showed malware behavior consistent with the TanStack supply-chain attack. The company rotated credentials and code-signing certificates as a precaution and stated there was no impact to customer data or production systems.

Why it matters: Supply-chain attacks can propagate broadly through trusted package ecosystems and CI/CD, exposing credentials, signing material, and internal source repositories.

Recommendation: Audit CI/CD workflows (especially GitHub Actions), rotate tokens/secrets, enforce least-privilege on publishing, and add install-time controls to detect suspicious package behavior.

Sources: <https://www.bleepingcomputer.com/news/security/openai-confirms-security-breach-in-tanstack-supply-chain-attack/> | <https://openai.com/index/our-response-to-the-tanstack-npm-supply-chain-attack/> | <https://socket.dev/blog/tanstack-npm-packages-compromised-mini-shai-hulud-supply-chain-attack>

05. [+24h Old] TeamPCP advertises nearly 450 Mistral AI repositories for sale after supply-chain fallout

TeamPCP claimed it stole internal repositories and source code and attempted to monetize the theft by selling access. Mistral stated that the incident was linked to the TanStack supply-chain attack and said core services and user data were not compromised.

Why it matters: Even limited developer-environment compromise can cascade into code leakage, SDK contamination, and credential theft across downstream users.

Recommendation: Rotate all affected CI/CD secrets, review package integrity and provenance, and scan for post-compromise persistence in developer tools and runners.

Sources: <https://www.bleepingcomputer.com/news/security/teampcp-hackers-advertise-mistral-ai-code-repos-for-sale/> | <https://docs.mistral.ai/resources/security-advisories>

06. [+24h Old] NoVoice Android malware used 50+ Google Play apps to exploit older Android bugs and deploy a rootkit

McAfee described NoVoice as an Android operation that hides payloads via steganography and attempts privilege escalation using vulnerabilities patched between 2016-2021. Once rooted, it can hook system libraries and steal WhatsApp session material for account takeover.

Why it matters: Devices on outdated patch levels may be fully compromised, with persistence that can survive typical cleanup and enable messaging session cloning.

Recommendation: Ensure devices run supported Android versions with recent security patches, enable Play Protect, and treat previously-installed affected apps as a potential compromise indicator.

Sources: <https://www.bleepingcomputer.com/news/security/novoice-android-malware-on-google-play-infected-23-million-devices/> | <https://www.mcafee.com/blogs/other-blogs/mcafee-labs/new-research-operation-novoice-rootkit-malware-android/>

07. [+24h Old] Google tracks UNC6783 targeting BPOs and Zendesk support to exfiltrate corporate data for extortion

Google Threat Intelligence Group reported UNC6783 compromising business process outsourcing providers to reach high-value enterprises and steal support tickets. The actor also used spoofed Okta login pages resembling Zendesk patterns to bypass MFA and register devices.

Why it matters: BPO compromise can provide leverage into many downstream clients, enabling large-scale data theft and extortion across multiple brands.

Recommendation: Deploy phishing-resistant MFA (FIDO2), monitor live-chat workflows for abuse, and block lookalike Zendesk-support domains.

Sources: <https://www.bleepingcomputer.com/news/security/google-new-unc6783-hackers-steal-corporate-zendesk-support-tickets/amp/> | <https://cloud.google.com/blog/topics/threat-intelligence>

08. [+24h Old] GhostPoster browser extension campaign persists with add-ons hiding malicious JavaScript in images

LayerX reported additional GhostPoster-linked extensions across Chrome/Firefox/Edge that use image-based payload containers and obfuscated staging logic. The activity supports tracking, affiliate hijacking, and ad fraud, and includes longer dormancy to evade detection.

Why it matters: Malicious extensions can capture browsing activity and tokens, enabling credential theft and unauthorized access to enterprise apps via the browser.

Recommendation: Audit installed extensions, enforce enterprise allowlists, and monitor for extension network calls to unusual external hosts and injected scripts/iframes.

Sources: <https://www.bleepingcomputer.com/news/security/malicious-ghostposter-browser-extensions-found-with-840-000-installs/> | <https://layerxsecurity.com/blog/browser-extensions-gone-rogue-the-full-scope-of-the-ghostposter-campaign/>

09. [+24h Old] ClickFix-style macOS campaigns abuse fake Homebrew/LogMeIn pages to deliver AMOS and Odyssey stealers

Hunt.io documented a malvertising ecosystem using dozens of lookalike domains and Terminal 'copy/paste' lures to fetch scripts and install macOS infostealers. Payloads include AMOS (Atomic macOS Stealer) and Odyssey, targeting browser data and crypto wallets.

Why it matters: Developer endpoints are high-value targets; successful infection can lead to credential and token theft, cloud compromise, and financial theft via wallets.

Recommendation: Block lookalike domains, educate users not to run pasted shell commands, and deploy EDR controls to detect suspicious curl|bash and quarantine-flag removal.

Sources: <https://www.bleepingcomputer.com/news/security/google-ads-for-fake-homebrew-logmein-sites-push-infostealers/> | <https://hunt.io/blog/macos-odyssey-amos-malware-campaign>

10. [+24h Old] Font-rendering 'Poisoned Typeface' trick can hide malicious commands from AI assistants reviewing webpages

LayerX demonstrated a mismatch between what the user sees and what an LLM reads from the DOM by remapping glyphs via custom fonts. Attackers can show a dangerous command to the user while exposing benign text to the assistant, encouraging unsafe actions.

Why it matters: Users may rely on AI assistants for safety checks; this technique undermines those checks and can increase successful social engineering for command execution.

Recommendation: Treat AI safety checks as advisory only; vendors should compare rendered view vs DOM and flag suspicious font/CSS obfuscation patterns.

Sources: <https://www.bleepingcomputer.com/news/security/new-font-rendering-trick-hides-malicious-commands-from-ai-tools/> | <https://layerxsecurity.com/blog/poisoned-typeface-a-simple-font-rendering-poisons-every-ai-assistant-and-only-microsoft-cares>

Latest Vulnerabilities (10)

01. DirtyDecrypt (DirtyCBC) Linux kernel page-cache write flaw now has a public root escalation PoC

A proof-of-concept exploit was released for a Linux kernel rxgk module issue that can yield root privileges on certain configurations. The bug aligns with CVE-2026-31635 and impacts distributions closely tracking upstream kernels when CONFIG_RXGK is enabled.

Why it matters: Public PoCs typically accelerate weaponization; unpatched hosts may be quickly compromised after initial foothold to gain full root control.

Recommendation: Apply kernel updates promptly; where patching is delayed, consider temporary mitigations that disable vulnerable modules (with awareness of VPN/AFS impact).

Sources: <https://www.bleepingcomputer.com/news/security/exploit-available-for-new-dirtydecrypt-linux-root-escalation-flaw/> | <https://nvd.nist.gov/vuln/detail/CVE-2026-31635>

02. NGINX Rift (CVE-2026-42945) exploitation begins days after PoC disclosure

SecurityWeek reports VulnCheck detecting active exploitation attempts against CVE-2026-42945, a heap overflow in ngx_http_rewrite_module. Default configs may see DoS via worker crash/restart, while RCE is possible when ASLR is disabled and certain rewrite configs exist.

Why it matters: Internet-facing NGINX deployments are widespread; exploitation can cause disruption and, in edge cases, remote code execution leading to full server compromise.

Recommendation: Patch NGINX/F5 NGINX immediately, review rewrite rules exposure, and ensure ASLR is enabled across deployments.

Sources: <https://www.securityweek.com/exploitation-of-critical-nginx-vulnerability-begins/> | <https://nvd.nist.gov/vuln/detail/CVE-2026-42945>

03. Pwn2Own Berlin 2026 concludes with 47 demonstrated zero-days and \$1.3M in payouts

The contest concluded with 47 unique zero-days demonstrated against fully patched products across enterprise and AI categories. Vendors have a standard 90-day window to ship patches before public disclosure by ZDI.

Why it matters: Enterprises should anticipate future patch waves across browsers, virtualization, and enterprise software targeted at the contest.

Recommendation: Track upcoming vendor advisories, prioritize patches tied to contest targets you operate, and validate compensating controls while waiting for fixes.

Sources: <https://www.bleepingcomputer.com/news/security/hackers-earn-1-298-250-for-47-zero-days-at-pwn2own-berlin-2026/> | <https://www.zerodayinitiative.com/blog/2026/5/16/pwn2own-berlin-2026-day-three-results-and-master-of-pwn>

04. MiniPlasma Windows privilege escalation zero-day PoC claims SYSTEM on fully patched Windows 11

A researcher released a PoC exploit named MiniPlasma targeting the Cloud Filter driver (cldflt.sys), claiming a 2020 issue remains exploitable. Testing reported SYSTEM-level command execution on fully patched Windows 11, raising concerns of rapid in-the-wild abuse.

Why it matters: Public exploit code for LPE can be combined with phishing or malware to quickly escalate privileges and disable defenses or harvest credentials.

Recommendation: Monitor for exploit indicators and suspicious registry/file operations; apply vendor updates when available and enforce least-privilege and EDR controls.

Sources: <https://www.bleepingcomputer.com/news/microsoft/new-windows-miniplasma-zero-day-exploit-gives-system-access-poc-released/> | <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2020-17103>

05. [+24h Old] Azure Backup for AKS 'confused deputy' privilege escalation report sparks silent patch controversy

A researcher alleged that the low-privilege Backup Contributor role could be abused to gain cluster-admin via Trusted Access in Azure Backup for AKS. The report was rejected and no CVE issued, but the researcher observed behavior changes consistent with a silent fix.

Why it matters: Lack of CVE/advisory reduces defender visibility, making it harder to assess exposure windows and enforce remediation governance.

Recommendation: Review RBAC for backup vault roles, ensure Trusted Access is explicitly configured and audited, and log/alert on unexpected backup enablement actions.

Sources: <https://www.bleepingcomputer.com/news/security/microsoft-rejects-critical-azure-vulnerability-report-no-cve-issued/> | <http://olearysec.com/research/azure-backup-aks-silent-patch/>

06. [+24h Old] Cisco Catalyst SD-WAN Controller auth bypass (CVE-2026-20182) actively exploited in zero-day attacks

Cisco disclosed CVE-2026-20182 (CVSS 10.0), an authentication bypass in SD-WAN peering that can allow login as a high-privileged internal account. The flaw has been

exploited in the wild; Cisco provided IOCs and urged upgrades.

Why it matters: Successful exploitation can enable rogue peer registration and SD-WAN fabric manipulation, potentially enabling deep network compromise.

Recommendation: Patch to fixed releases, restrict management/control plane exposure to trusted IPs, and audit auth logs and peering events for anomalies.

Sources: <https://www.bleepingcomputer.com/news/security/cisco-warns-of-new-critical-sd-wan-flaw-exploited-in-zero-day-attacks/> | <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisor/cisco-sa-sdwan-rpa2-v69WY2SW>

07. [+24h Old] Fragnesia (CVE-2026-46300) Linux kernel flaw allows unprivileged root via page-cache writes

Fragnesia is a Dirty Frag class bug in the Linux XFRM ESP-in-TCP subsystem enabling arbitrary byte writes into page cache of read-only files. A PoC demonstrates corrupting /usr/bin/su in memory to obtain root privileges.

Why it matters: Local privilege escalation with a PoC increases risk for servers and developer endpoints where initial access is achievable through other vectors.

Recommendation: Apply kernel updates; if needed, temporarily unload esp4/esp6/rxrpc modules with awareness of operational tradeoffs.

Sources: <https://www.bleepingcomputer.com/news/security/new-fragnesia-linux-flaw-lets-attackers-gain-root-privileges/> | <https://nvd.nist.gov/vuln/detail/CVE-2026-46300>

08. [+24h Old] Windows BitLocker 'YellowKey' and 'GreenPlasma' zero-day PoCs published by disgruntled researcher

Two PoCs were published: YellowKey targets WinRE behavior to bypass TPM-only BitLocker drive protection on the original device, while GreenPlasma is a privilege escalation concept. Independent researchers validated key aspects and urged stronger BitLocker configurations.

Why it matters: Physical access plus exploit chain may expose data on endpoints using TPM-only BitLocker, and LPE PoCs can enable rapid post-compromise escalation.

Recommendation: Prefer BitLocker with additional factors (PIN) where possible, set strong BIOS/UEFI passwords, and restrict access to recovery environments and removable media boot.

Sources: <https://www.bleepingcomputer.com/news/security/windows-bitlocker-zero-day-gives-access-to-protected-drives-poc-released/> | <https://github.com/Nightmare-Eclipse/YellowKey>

09. [+24h Old] Exim SMTP server critical RCE (CVE-2026-45185) fixed in Exim 4.99.3

CVE-2026-45185 is a use-after-free in Exim (GnuTLS builds with STARTTLS and CHUNKING) triggered during TLS shutdown handling BDAT traffic. The bug can allow unauthenticated remote code execution on affected configurations.

Why it matters: Email infrastructure compromise can enable message interception, lateral movement, and domain footholds in shared hosting and enterprise environments.

Recommendation: Upgrade to Exim 4.99.3 (or distro patches) and confirm whether your build uses GnuTLS with STARTTLS+CHUNKING enabled.

Sources: <https://www.bleepingcomputer.com/news/security/new-critical-exim-mailer-flaw-allows-remote-code-execution/> | <https://nvd.nist.gov/vuln/detail/CVE-2026-45185>

10. [+24h Old] Apple ships first 'Background Security Improvements' out-of-band update to patch WebKit CVE-2026-20643

Apple used its Background Security Improvements mechanism to deliver a WebKit fix for CVE-2026-20643 without requiring a full OS upgrade. The issue could allow malicious web content to bypass the Same Origin Policy via a cross-origin Navigation API flaw.

Why it matters: WebKit browser bugs are frequently exploited in the wild; faster patch delivery reduces exposure windows, especially on mobile fleets.

Recommendation: Keep Background Security Improvements enabled, avoid uninstalling the background patch unless it causes device issues, and maintain timely OS updates.

Sources: <https://www.bleepingcomputer.com/news/security/apple-pushes-first-background-security-improvements-update-to-fix-webkit-flaw/> | <https://support.apple.com/en-us/126604>

Data Breach & Cybercrime (10)

01. [+24h Old] ShinyHunters defaces hundreds of Canvas login portals in renewed Instructure extortion campaign

Attackers defaced Canvas login portals for hundreds of educational institutions, displaying extortion messages and threatening to leak previously stolen data. The disruption was visible briefly before portals were taken offline, with reports of broader impact on schools.

Why it matters: Large-scale disruption during academic periods can cause operational outages and increases the risk of student/teacher data exposure and follow-on phishing.

Recommendation: Review Canvas admin session security, patch XSS exposures, and prepare targeted phishing warnings to impacted user communities.

Sources: <https://www.bleepingcomputer.com/news/security/canvas-login-portals-hacked-in-mass-shinyhunters-extortion-campaign/> | <https://www.bleepingcomputer.com/news/security/us-govt-seeks-instructure-testimony-on-massive-canvas-cyberattack/>

02. [+24h Old] US House Homeland Security Committee requests Instructure briefing after repeated Canvas breaches

A congressional committee asked Instructure leadership to brief investigators on two ShinyHunters incidents involving student/staff data exposure and service disruption. The letter highlights widespread impact across states and questions incident response practices.

Why it matters: Regulatory and legislative scrutiny can expand breach costs, accelerate disclosure requirements, and increase litigation and compliance risk.

Recommendation: Ensure incident documentation is complete, validate breach notifications, and review third-party and SaaS security controls for systemic weaknesses.

Sources: <https://www.bleepingcomputer.com/news/security/us-govt-seeks-instructure-testimony-on-massive-canvas-cyberattack/> | <https://homeland.house.gov/wp-content/uploads/2026/05/2026.05.11-Homeland-to-Instructure-Holdings-Inc.pdf>

03. [+24h Old] McGraw-Hill confirms unauthorized access via Salesforce-hosted webpage; ShinyHunters claims extortion

McGraw-Hill said attackers accessed a limited set of data tied to a Salesforce-hosted webpage, describing it as part of broader Salesforce environment misconfiguration issues affecting multiple organizations. The company stated sensitive student data and financial identifiers were not exposed.

Why it matters: Even limited web-exposed datasets can fuel targeted phishing and extortion narratives; Salesforce ecosystem incidents can cascade across many customers.

Recommendation: Audit publicly exposed Salesforce pages and integrations, rotate any exposed secrets/tokens, and monitor for extortion attempts and data-leak claims.

Sources: <https://www.bleepingcomputer.com/news/security/mcgraw-hill-confirms-data-breach-following-extortion-threat/> | <https://www.bleepingcomputer.com/tag/salesforce/>

04. [+24h Old] Telus Digital confirms breach after ShinyHunters claims ~1PB data theft impacting multiple customers

Telus Digital confirmed unauthorized access to some systems while ShinyHunters claimed a very large data theft spanning multiple customer environments and internal datasets. The threat actor alleged initial access via cloud credentials discovered in earlier third-party data theft.

Why it matters: BPO compromise can become a multi-victim incident with complex notification scope, exposing call records, support data, and operational analytics.

Recommendation: Rotate cloud credentials and secrets, validate access logs for BigQuery/Snowflake and other analytics platforms, and segment BPO access paths with least-privilege controls.

Sources: <https://www.bleepingcomputer.com/news/security/telus-digital-confirms-breach-after-hacker-claims-1-petabyte-data-theft/amp/> | <https://cloud.google.com/blog/topics/threat-intelligence/data-theft-salesforce-instances-via-salesloft-drift>

05. [+24h Old] Vimeo says Anodot third-party breach exposed some user data (primarily metadata and some emails)

Vimeo disclosed an incident linked to the Anodot breach where an unauthorized actor accessed some customer/user data. Vimeo stated that video content, credentials, and payment data were not exposed and that integrations were disabled and credentials rotated.

Why it matters: Third-party token compromise can cascade into downstream Snowflake/BigQuery data exposure and create extortion pressure even when core systems are unaffected.

Recommendation: Review third-party integrations, rotate API keys/tokens, and continuously monitor data warehouse access for anomalous exports.

Sources: <https://www.bleepingcomputer.com/news/security/video-service-vimeo-confirms-anodot-breach-exposed-user-data/amp/> | <https://vimeo.com/blog/post/anodot-third-party-security-incident>

06. [+24h Old] Grubhub confirms data was downloaded in a breach; sources link extortion to ShinyHunters

Grubhub confirmed unauthorized data downloads from certain systems and reported it stopped the activity and engaged incident response support. Sources told BleepingComputer the incident involved extortion and referenced previously stolen Salesforce/Zendesk data.

Why it matters: Support-ticket and CRM data can contain sensitive PII and operational details that enable social engineering and account takeover attempts.

Recommendation: Rotate credentials and OAuth tokens tied to support tooling (Zendesk/Salesforce), and audit subdomains used for email campaigns and tracking links.

Sources: <https://www.bleepingcomputer.com/news/security/grubhub-confirms-hackers-stole-data-in-recent-security-breach/amp/> | <https://www.bleepingcomputer.com/news/security/salesloft-breached-to-steal-oauth-tokens-for-salesforce-data-theft-attacks/>

07. [+24h Old] Eurail warns stolen traveler data is for sale on dark web after earlier customer database breach

Eurail said data from a prior breach is being offered for sale and a sample was posted on Telegram. Exposed information may include passport/ID details, IBANs, and contact info, with notifications planned as impact is confirmed.

Why it matters: Passport/ID and banking identifiers are high-risk for identity fraud and targeted phishing, especially for travelers and students using passes.

Recommendation: Advise impacted users to monitor financial activity, rotate reused passwords, and be alert for impersonation scams; organizations should strengthen database access controls and audit logs.

Sources: https://www.bleepingcomputer.com/news/security/eurail-says-stolen-traveler-data-now-up-for-sale-on-dark-web/?web_view=true | <https://www.eurail.com/en/ni/data-security-incident>

08. [+24h Old] German authorities shut down Crimenetwork marketplace reboot and arrest alleged operator in Spain

Authorities arrested a suspect accused of rebuilding the Crimenetwork cybercrime marketplace shortly after its earlier takedown. Investigators seized infrastructure and data, noting the reboot amassed tens of thousands of users and significant illicit revenue.

Why it matters: Marketplace takedowns disrupt criminal supply chains but often lead to rapid reconstitution; seized user/vendor data can enable further arrests and intelligence.

Recommendation: Continue monitoring for successor marketplaces and leaked datasets; enterprises should assume stolen access and credentials circulate widely in such markets.

Sources: <https://www.bleepingcomputer.com/news/security/police-shut-down-reboot-of-crimenetwork-marketplace-arrest-admin/> | https://www.bka.de/DE/Presse/Listenseite_Pressemitteilungen/2026/Presse2026/260508_PM_Crimenetwork.html

09. [+24h Old] Ukraine arrests suspect accused of breaching 5,000 hosting accounts and cryptojacking via cloud VMs

Ukrainian cyberpolice said a suspect abused compromised hosting accounts to deploy unauthorized virtual machines for cryptocurrency mining, creating multi-million dollar damages. Investigators seized devices and traced activity to forum accounts and stolen credentials.

Why it matters: Cryptojacking consumes compute resources, creates unexpected costs, and often indicates broader credential compromise and persistence in cloud environments.

Recommendation: Enforce MFA on hosting/cloud consoles, monitor for anomalous VM provisioning and spend spikes, and rotate credentials after any suspicion of account takeover.

Sources: <https://www.bleepingcomputer.com/news/security/hacker-arrested-for-breaching-5-000-hosting-accounts-to-mine-crypto/> | <https://cyberpolice.gov.ua/news/kiberpolicziya-zaporizhzhya-vykryla-xakera-yakyj-zavdav-poterpily-miljonni-zbytky-na-majningu-kryptovalyuty-5154/>

10. [+24h Old] Advance Auto Parts confirms third-party cloud database breach exposed employee SSNs and other identifiers

Advance Auto Parts reported unauthorized activity in a third-party cloud database and said data believed to include employee/applicant personal information was accessed. The company planned notifications and credit monitoring and reported related costs in filings.

Why it matters: Exposure of SSNs and government IDs increases identity theft risk and drives regulatory notification requirements and long-term fraud monitoring needs.

Recommendation: Minimize sensitive data stored in third-party databases, enforce strong access controls, and provide rapid identity-protection guidance to affected individuals.

Sources: <https://www.bleepingcomputer.com/news/security/advance-auto-parts-confirms-data-breach-exposed-employee-information/> | <https://www.sec.gov/Archives/edgar/data/1158449/000115844924000162/aap-20240523.htm>